

Capitolo 1 - Inizio

1 Definizioni e Obiettivi della Sicurezza (CIA Triad)

La sicurezza informatica viene definita dal NIST (NISTIR 7298) come l'insieme delle misure e dei controlli volti a garantire la riservatezza, l'integrità e la disponibilità degli asset di un sistema informativo. Questi asset includono hardware, software, firmware e le informazioni stesse. Questi tre concetti fondamentali formano la cosiddetta Triade CIA:

- **Confidenzialità (Confidentiality):** Si divide in riservatezza dei dati (le informazioni non devono essere divulgate a soggetti non autorizzati) e privacy (il controllo degli individui su quali informazioni che li riguardano possono essere raccolte e a chi possono essere rivelate). Una perdita di confidenzialità consiste nella divulgazione non autorizzata di dati.
- **Integrità (Integrity):** Include l'integrità dei dati (informazioni e programmi vengono modificati solo in modo autorizzato) e l'integrità del sistema (il sistema svolge le sue funzioni senza manipolazioni non autorizzate, accidentali o deliberate). Una perdita di integrità si traduce nella modifica o distruzione non autorizzata di informazioni.
- **Disponibilità (Availability):** Assicura che i sistemi e i servizi funzionino prontamente e che l'accesso alle informazioni sia garantito in modo affidabile agli utenti autorizzati. Una perdita di disponibilità comporta l'interruzione dell'accesso o dell'uso delle risorse.

Oltre alla triade classica, si considerano spesso altri due concetti cardine: l'**Autenticità**, ovvero la capacità di verificare che un utente o un messaggio siano chi dicono di essere e che la sorgente sia fidata, e la **Responsabilità (Accountability)**, che richiede che le azioni di un'entità siano tracciate in modo univoco per permettere analisi forensi e risalire ai responsabili in caso di violazioni.

2 Le tipologie di rischio e di impatto

Se vengono a mancare delle caratteristiche delle triade CIA o direttamente tutta la triade, si può incappare in impatti su organizzazioni o individui di diversa portata:

Basso

In questo scenario, la perdita di sicurezza ha ripercussioni limitate sulle operazioni o sugli asset dell'organizzazione. Nello specifico, si verifica un degrado delle capacità operative tale per cui le funzioni primarie possono ancora essere svolte, ma con un'efficacia notevolmente ridotta. I danni ai beni aziendali, le perdite finanziarie e gli eventuali danni alle persone sono considerati di lieve entità.

Medio

In caso di impatto moderato, la compromissione della sicurezza causa un degrado significativo delle capacità operative. Sebbene l'organizzazione riesca ancora a svolgere le sue funzioni principali, la loro efficacia risulta compromessa in modo rilevante. Questo livello comporta danni consistenti ai beni materiali o immateriali e perdite finanziarie significative. Per quanto riguarda le persone, possono verificarsi danni rilevanti, ma che non includono il pericolo di vita o lesioni gravi e permanenti.

Alto

Questo è lo scenario più critico, in cui la perdita di sicurezza causa un degrado grave o la perdita totale delle capacità operative, rendendo l'organizzazione incapace di svolgere una o più delle sue funzioni primarie. Si registrano danni enormi ai beni aziendali e perdite finanziarie major. L'impatto sugli individui è classificato come grave o catastrofico, con il rischio concreto di perdita della vita o lesioni gravissime che mettono a repentaglio la salute.

3 Modello per la sicurezza informatica

Il seguente modello mostra la relazione tra le varie caratteristiche del modello tra cui le risorse del sistema (o asset) e tutto quello che ne concerne:

Asset

Le risorse di un sistema informatico possono essere categorizzate come segue:

- **Hardware:** include i sistemi informatici e altri dispositivi per l'elaborazione, l'archiviazione e la comunicazione dei dati.
- **Software:** include il sistema operativo, le utility di sistema e le applicazioni.
- **Dati:** include file e database, così come i dati relativi alla sicurezza, quali i file di password.
- **Strutture e reti di comunicazione:** link di comunicazione delle local e delle wide area network, bridge, router e così via.

4 Vulnerabilità dell'asset

- **Minaccia (Threat):** Qualsiasi circostanza o evento che ha il potenziale di influire negativamente sulle operazioni aziendali (inclusa la missione, l'immagine o la reputazione), sui beni dell'organizzazione o sulle persone. Ciò può avvenire tramite l'accesso non autorizzato, la distruzione, la divulgazione o la modifica di informazioni e l'interruzione del servizio (denial of service).
- **Avversario (Threat Agent):** Un individuo, gruppo, organizzazione o governo che mette in atto (o ha l'intento di farlo) attività dannose verso il sistema.
- **Attacco (Attack):** Qualsiasi tipo di attività malevola che tenta di raccogliere, interrompere, negare, degradare o distruggere le risorse del sistema informativo o le informazioni stesse.
- **Contromisura (Countermeasure):** Un dispositivo o una tecnica che ha l'obiettivo di ridurre l'efficacia operativa di attività avversarie o indesiderate. Serve a prevenire spionaggio, sabotaggio, furto o accessi non autorizzati a informazioni sensibili.
- **Rischio (Risk):** Rappresenta la misura in cui un'entità è minacciata da un potenziale evento. È tipicamente una funzione di due fattori: l'impatto negativo che deriverebbe dall'evento e la probabilità che tale evento si verifichi.

$$R = P \times D$$

- **Security Policy:** Un insieme di criteri per l'erogazione dei servizi di sicurezza. Definisce e vincola le attività di un centro di elaborazione dati al fine di mantenere una condizione di sicurezza per sistemi e dati.

5 Vulnerabilità, minacce e attacchi

Generalmente distinguiamo i tre macro tipi di vulnerabilità in base a come è in quel momento il sistema:

- **Il sistema può essere corrotto:** opera in modo errato o dà risposte sbagliate (es. modifica impropria dei dati).
- **Il sistema può avere una falla:** accesso non autorizzato alle informazioni attraverso la rete.

- **Il sistema può diventare non disponibile o molto lento:** l'uso del sistema o della rete diventa impossibile o infattibile.

A questi tipi di vulnerabilità corrispondono i concetti di integrità, confidenzialità e disponibilità.

6 Minacce e Risorse

Conseguenza della minaccia	Azione minatoria (attacco)
Divulgazione non autorizzata: Accesso a dati per i quali l'entità non è autorizzata. Intercettazione: Accesso ai dati in transito. Inferenza: Accesso indiretto basato su caratteristiche delle comunicazioni. Intrusione: Accesso aggirando le protezioni.	Esposizione: Dati rivelati direttamente.
Inganno: Ricezione di dati falsi creduti veri. Falsificazione: Dati falsi che ingannano. Ripudio: Negare falsamente la responsabilità.	Mascheramento: Spacciarsi per un'entità autorizzata.
Interruzione: Impedire il corretto funzionamento dei servizi. Corruzione: Alterare funzioni o dati. Ostruzione: Ostacolare il funzionamento.	Interdizione: Disabilitare componenti.
Usurpazione: Controllo non autorizzato di servizi o funzioni. Uso improprio: Esecuzione di funzioni dannose.	Appropriazione indebita: Controllo logico o fisico.

7 Classificazione degli Attacchi

1. Attivo vs Passivo:

- **Attivo:** Tentativo di alterare risorse o influenzare il funzionamento (es. replay, mascheramento, modifica messaggi, DoS).
- **Passivo:** Tentativo di apprendere informazioni senza influire sulle risorse (es. lettura contenuto, analisi del traffico).

2. Interno vs Esterno:

- **Interno:** Lanciato da un "insider" autorizzato ad accedere ma che usa le risorse in modo non autorizzato.
- **Esterno:** Lanciato da un "outsider" (criminali, terroristi, governi ostili) fuori dal perimetro di sicurezza.

8 Contromisure e Principi di Design

Secondo lo standard FIPS 200, le contromisure si dividono in:

- **Tecniche:** Controllo accessi, autenticazione, protezione comunicazioni, integrità.
- **Funzionali:** Formazione, audit, manutenzione, sicurezza del personale, pianificazione.
- **Ibride:** Gestione configurazione, risposta agli incidenti, protezione dei media.

Principi Fondamentali di Design

- **Economia dei meccanismi:** Design semplice e piccolo.
- **Fail-safe defaults:** Accesso negato di default.
- **Mediazione completa:** Ogni accesso deve essere controllato.

- **Open Design:** Il meccanismo non deve essere segreto.
- **Minimo privilegio:** Solo i privilegi necessari per il compito.
- **Difesa in profondità (Layering):** Barriere multiple sovrapposte.

9 Superfici e Alberi di Attacco

L'**Attack Surface** è l'insieme delle vulnerabilità raggiungibili (Rete, Software, Umana). Gli **Alberi di Attacco** sono strutture gerarchiche dove la radice è l'obiettivo e i nodi sono i sotto-obiettivi collegati da porte logiche AND/OR.